

Industrial Security (Bachelor)

Exercise Sheet – Section 10 Incident Response and Recovery

Goal of this sheet: drill the decisions, escalations, and artefacts that turn an OT incident from chaos into a managed event. Each task is scenario-driven and asks you to apply NIST SP 800-61 Rev. 2, SANS ICS515, NIS2 Art. 23, and the forensic guidance of NIST SP 800-86 to concrete OT situations. Three to ten sentences of reasoning per task is enough; show your trade-offs, not your vocabulary.

Exercise 10.1 – Tabletop: 03:00 Sunday Historian Ransomware

At 03:00 on a Sunday, the night-shift operator at a mid-size chemical plant reports that the Historian database is encrypted; a ransom note sits on the console. The SCADA HMI is still live but trends are flat. Walk through the **first four hours**: list every decision (with the decision owner), every escalation (with the role and target), and every notification (internal and external). Assume the plant falls under NIS2 as an essential entity. Anchor your timeline against the NIST SP 800-61 Rev. 2 phases (Detection & Analysis, Containment, Eradication, Recovery).

Exercise 10.2 – Forensic Scope by Asset Class

For each of the four asset classes below, list in three columns: (a) what you *can* pull as forensic evidence, (b) what you *cannot* pull (and why), (c) what compensating evidence exists elsewhere. Cite NIST SP 800-86 or SANS ICS515 where relevant.

- Schneider M580 or Siemens S7-1500 **PLC**
- Windows-based **HMI**
- **Engineering workstation** (TIA Portal / Studio 5000 / Unity Pro)
- **Network** layer (L2 access switch, L3 boundary, iDMZ)

Exercise 10.3 – RACI for “Shut Down Unit 2”

The decision on the table is: *“Shut down Unit 2 due to suspected compromise of its DCS.”* Build a single RACI row (Responsible, Accountable, Consulted, Informed) for this decision across the following roles: security operations, plant manager, SCADA / DCS engineer, HSE officer, legal, and PR / communications. Each role must appear in exactly one column. Defend in two sentences who is *Accountable* and why it is not security.

Exercise 10.4 – Recovery Validation of a Re-Flashed M580

A Schneider Modicon M580 was re-flashed with vendor firmware and reloaded with the last signed project after a suspected compromise. Before production sign-off, list **six checks** you would run, in order. For each check name the artefact, the tool, and the pass criterion. Reference the “heightened monitoring window” concept from FIRST CSIRT guidance and the signed-baseline idea from the slides.

Exercise 10.5 – NIS2 Art. 23 Early Warning Draft

An EU-based water utility (essential entity under NIS2) detects a confirmed compromise of its SCADA jump host at 22:15 on a Tuesday. Draft the **24-hour early warning** to the national CSIRT under Directive (EU) 2022/2555 Art. 23(4)(a). Three to five sentences, suitable for paste into the regulator portal. The text must state suspected malicious cause, whether cross-border impact is plausible, and that this is an early warning (not the notification or final report). Do *not* speculate on attribution.

Exercise 10.6 – RTO / RPO Assignment with Justification

Assign a realistic Recovery Time Objective (RTO) and Recovery Point Objective (RPO) to each of the following systems for a chemical plant. Give each assignment a one-sentence justification anchored in the consequence of loss (safety, regulatory, financial, reputational). Present as a single five-column table (System / RTO / RPO / Consequence / Justification).

- Process Historian
- Manufacturing Execution System (MES)
- SCADA HMI
- Safety Instrumented System (SIS)
- Customer billing IT
- Engineering document management

Exercise 10.7 – Blameless vs. Blameful Post-Mortem Opener

Write two short post-mortem openers (one paragraph each, 4–6 sentences) for the same fictional incident: an operator clicked a phishing link on a control-room PC that allowed lateral movement to the Historian.

- **Blameless** version that would not chill future reporting.
- **Blameful** version that names the operator and frames the incident as personal failure.

Then add two sentences contrasting them: what does the blameless version unlock that the blameful version closes?

Exercise 10.8 – Tabletop Design: Foreign-State Pre-Positioning

Design a 90-minute tabletop for the scenario: *“Foreign-state pre-positioning detected on your engineering workstation; no destructive action yet, but persistent C2 beaconing and PLC project-file access.”* Deliver:

- Inject timeline (at least four injects with realistic timestamps).
- Three expected discussion moments where the room is supposed to struggle (for example: re-image now and tip the adversary?).
- Five success criteria the facilitator scores the team against.

Exercise 10.9 – “Pull the Cable” Counter-Examples

In OT, the IT instinct of “pull the cable” is often the wrong move. Give **two distinct scenarios** where disconnecting the affected asset would make the incident strictly worse (process safety, regulatory, or evidence preservation), and for each scenario name the alternative containment action you would take instead. One scenario must involve a Safety Instrumented System or safety-critical loop.

Exercise 10.10 – Lessons-Learned Feedback Artefacts

After a real incident, the post-mortem report is only one of the artefacts that should flow back into the Preparation phase of NIST SP 800-61. List **five other concrete artefacts** that should feed back into Preparation, and for each name (a) who owns the update, (b) where it lives, and (c) the trigger that says “yes, this artefact has been updated.”